

# Security+ 1.4 · Public Key Infrastructure (PKI)

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 1.4 — Public Key Infrastructure (PKI)** (9:08) · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

---

**Resumo Executivo da Aula:** PKI: o fundamento da criptografia moderna — SIMÉTRICA (AES — mesma chave, rápida, boa pra volume) vs ASSIMÉTRICA (RSA/ECC — par de chave pública/privada, lenta, boa pra troca e assinatura). Key escrow = cópia de chave em cofre.

## Highlights que a prova cobra

---

- AES = simétrico; RSA = assimétrico
- Assimétrico: pública cifra, privada decifra (ou assina)
- PGP: combina a 2 (RSA pra trocar a chave + AES pro conteúdo)

## Dicas de prova & Cenários Típicos

---

- 'requires a mathematical relationship between two cryptographic keys' = assimétrica (PKI)
- AES vs RSA: não confunde — a prova gosta de citar algoritmos

**Cenário clássico de exame:** Cenário típico: 'empresa precisa que a mensagem só possa ser aberta pelo destinatário, sem compartilhar senha' → crypto assimétrica (par de chave).

## 🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 1.4 — Public Key Infrastructure (PKI))

**Por que este aprofundamento é cobrado no exame?** O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

### ⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

## ✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim.  
Tente responder antes de olhar.

### 1. AES é um exemplo de criptografia:

- A) Simétrica (mesma chave cifra e decifra)
- B) Assimétrica (par de chaves)
- C) Hash de mão única
- D) Codificação Base64

### 2. Qual tipo de criptografia usa pares de chaves pública e privada?

- A) Hashing
- B) Criptografia simétrica
- C) Criptografia assimétrica
- D) Steganografia

**3. Em uma infraestrutura PKI, qual componente é responsável por validar e revogar certificados digitais?**

- A)** RA (Registration Authority)
- B)** CA (Certificate Authority)
- C)** CRL (Certificate Revocation List)
- D)** OCSP (Online Certificate Status Protocol)

**4. Trocar uma chave secreta por canal público SEM enviá-la diretamente usa:**

- A)** Diffie-Hellman
- B)** AES
- C)** SHA-256
- D)** Base64

**5. Serviço que gerencia chaves de criptografia na nuvem (criar, rotacionar, controlar acesso):**

- A)** KMS (Key Management Service)
- B)** IAM
- C)** CDN
- D)** VPC

**6. Cenário corporativo (Public Key Infrastructure (PKI)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'AES = simétrico; RSA = assimétrico'. Qual é a melhor recomendação ou classificação de controle aplicável?**

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: AES = simétrico; RSA = assimétrico...

**7. Cenário corporativo (Public Key Infrastructure (PKI)):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Assimétrico: pública cifra, privada decifra (ou assina)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Assimétrico: pública cifra, privada decifra (ou assina)...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**8. Cenário corporativo (Public Key Infrastructure (PKI)):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'PGP: combina a 2 (RSA pra trocar a chave + AES pro conteúdo)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: PGP: combina a 2 (RSA pra trocar a chave + AES pro conteúdo)...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**9. Cenário corporativo (Public Key Infrastructure (PKI)):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'requires a mathematical relationship between two cryptographic keys' = assimétrica (PKI)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'requires a mathematical relationship between two cryptographic keys' = ass...

**10.** Cenário corporativo (Public Key Infrastructure (PKI)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'AES vs RSA: não confunde — a prova gosta de citar algoritmos'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: AES vs RSA: não confunde — a prova gosta de citar algoritmos...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

## GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

### 1) A — Simétrica (mesma chave cifra e decifra).

✓ **Por que está certa:** A alternativa correta é 'Simétrica (mesma chave cifra e decifra)'. AES (Advanced Encryption Standard) é um algoritmo de criptografia simétrica, o que significa que a mesma chave é usada tanto para cifrar quanto para decifrar os dados. É um padrão amplamente adotado, com tamanhos de chave de 128, 192 ou 256 bits, e é considerado seguro e eficiente. O CompTIA Security+ SY0-701, no domínio de Implementação de Segurança (3.3), lista AES como exemplo de criptografia simétrica. A questão pede a classificação correta de AES, que é simétrica.

#### ✗ **Por que as outras estão erradas:**

- *Assimétrica (par de chaves):* Criptografia assimétrica utiliza um par de chaves: uma pública para cifrar e uma privada para decifrar (ou vice-versa para assinaturas). Exemplos incluem RSA, ECC e Diffie-Hellman. AES não é assimétrico; ele usa uma única chave secreta compartilhada. Portanto, essa alternativa está incorreta.
- *Hash de mão única:* Funções de hash criptográfico, como SHA-256 e MD5, são de mão única: transformam dados de entrada em uma saída de tamanho fixo, sem possibilidade de reversão. Elas não usam chave e servem para integridade, não para confidencialidade. AES é um algoritmo de cifra reversível com chave, não um hash. Portanto, essa alternativa está incorreta.
- *Codificação Base64:* Base64 é uma codificação que representa dados binários em formato ASCII, usada para transmitir dados em ambientes que só suportam texto. Não é criptografia, pois não usa chave e é facilmente reversível. AES é um algoritmo criptográfico, não uma codificação. Portanto, essa alternativa está incorreta.

### 2) C — Criptografia assimétrica.

✓ **Por que está certa:** A alternativa correta é 'Criptografia assimétrica'. A criptografia assimétrica, também chamada de criptografia de chave pública, utiliza um par de chaves matematicamente relacionadas: uma chave pública, que pode ser distribuída livremente, e uma chave privada, mantida em segredo pelo proprietário. A chave pública é usada para cifrar dados ou verificar assinaturas digitais, enquanto a chave privada é usada para decifrar ou assinar. Exemplos incluem RSA, ECC e Diffie-Hellman. A CompTIA Security+ exige o entendimento de que a assimetria resolve o problema de distribuição de chaves e fornece confidencialidade, integridade, autenticação e não repúdio.

#### ✗ **Por que as outras estão erradas:**

- *Hashing:* Hashing é uma função criptográfica unidirecional que transforma uma entrada de tamanho variável em uma saída de tamanho fixo (digest). Não utiliza chaves e não é usada para cifrar/decifrar dados, mas sim para verificar integridade. A alternativa é incorreta porque hashing não envolve pares de chaves e não fornece confidencialidade.
- *Criptografia simétrica:* A criptografia simétrica usa uma única chave secreta compartilhada entre as partes para cifrar e decifrar. Exemplos: AES, DES, 3DES. Embora seja eficiente, não utiliza par de chaves pública e privada. A alternativa é incorreta porque descreve o modelo de chave única, não o modelo assimétrico.
- *Steganografia:* Steganografia é a arte de ocultar informações dentro de outros arquivos (imagens, áudios, vídeos) para que a existência da mensagem passe despercebida. Não envolve criptografia de chave pública ou privada. A alternativa é incorreta porque não é um método criptográfico baseado em chaves, mas sim uma técnica de ocultação.

### 3) B — CA (Certificate Authority).

✓ **Por que está certa:** A \*\*CA (Certificate Authority)\*\* é o componente central de uma PKI

responsável por emitir, validar e revogar certificados digitais. Ela assina digitalmente os certificados, garantindo a autenticidade e integridade das chaves públicas. Além disso, a CA mantém e publica a CRL (Certificate Revocation List) e/ou oferece o serviço OCSP (Online Certificate Status Protocol) para que terceiros possam verificar se um certificado ainda é válido. No syllabus da CompTIA Security+ (SY0-701), a CA é descrita como a entidade de confiança que valida identidades e gerencia o ciclo de vida dos certificados, incluindo a revogação. Portanto, a CA é a resposta exata para 'validar e revogar certificados digitais'.

**✗ Por que as outras estão erradas:**

- **RA (Registration Authority):** A RA (Registration Authority) é uma entidade subordinada à CA que atua como intermediária no processo de registro de usuários. Sua função principal é verificar a identidade do solicitante antes de encaminhar o pedido de certificado à CA, mas ela não emite, valida ou revoga certificados. A RA pode auxiliar na coleta de documentação e na autenticação inicial, porém a decisão final de emissão e revogação é sempre da CA. No contexto da pergunta, a RA não executa a validação e revogação de certificados, apenas facilita o registro, portanto está incorreta.
- **CRL (Certificate Revocation List):** A CRL é uma lista publicada periodicamente pela CA contendo os números de série dos certificados que foram revogados antes de sua data de expiração. Ela é um mecanismo de consulta para verificar se um certificado está revogado, mas não realiza a validação ou revogação em si. A CRL é um artefato gerado pela CA; ela não toma decisões nem executa ações de revogação. Além disso, a validação de um certificado envolve verificar a assinatura da CA, a cadeia de confiança e a validade temporal, o que não é feito pela CRL. Portanto, CRL é apenas uma ferramenta de consulta, não o componente responsável pela validação e revogação.
- **OCSP (Online Certificate Status Protocol):** O OCSP é um protocolo de consulta em tempo real que permite verificar se um certificado específico foi revogado, consultando diretamente a CA ou um respondedor OCSP. Ele oferece uma alternativa mais ágil que a CRL, mas não é o componente que valida ou revoga certificados; é apenas um serviço de verificação de status. A responsabilidade de emitir, validar e revogar certificados permanece com a CA. O OCSP depende da CA para obter as informações de revogação. Logo, não é a resposta correta para a função de validar e revogar certificados.

**4) A — Diffie-Hellman.**

- ✓ Por que está certa:** O algoritmo Diffie-Hellman (DH) e suas variantes efêmeras (DHE, ECDHE) permitem que duas partes estabeleçam uma chave secreta compartilhada através de um canal público inseguro, sem nunca transmitir a chave diretamente. Cada parte gera um par de chaves (privada e pública), troca as chaves públicas e, com sua chave privada e a chave pública da outra parte, calcula o mesmo segredo. Um observador que intercepte as chaves públicas não consegue derivar o segredo devido à dificuldade do problema do logaritmo discreto (ou do logaritmo discreto em curvas elípticas). Esse segredo é então usado para derivar chaves simétricas de sessão, garantindo confidencialidade mesmo em redes não confiáveis.

**✗ Por que as outras estão erradas:**

- **AES:** AES (Advanced Encryption Standard) é um algoritmo de criptografia simétrica por blocos, usado para cifrar dados em massa com uma chave secreta previamente compartilhada. Ele não resolve o problema de estabelecer essa chave secreta inicial em um canal público; se a chave AES fosse enviada diretamente, um interceptador a capturaria e poderia decifrar toda a comunicação. AES é o destinatário final do segredo gerado pelo Diffie-Hellman, não o mecanismo de troca em si.
- **SHA-256:** SHA-256 é uma função de hash criptográfico que produz um resumo de 256 bits a partir de uma entrada, usada para verificar integridade e em assinaturas digitais. Não é um

protocolo de acordo de chaves e não gera segredos compartilhados entre partes. Aplicar SHA-256 a uma chave não a torna secreta; o hash é unidirecional, mas não impede que um atacante que veja a entrada original descubra a chave. Portanto, SHA-256 não substitui Diffie-Hellman na troca segura de chaves.

- **Base64:** Base64 é uma codificação de dados binários em texto ASCII, usada para transportar informações em protocolos baseados em texto (como e-mail MIME). Não é criptografia nem acordo de chaves; é uma transformação reversível sem chave. Qualquer pessoa pode decodificar Base64 trivialmente. Usar Base64 para 'trocar uma chave secreta' significaria enviá-la em claro disfarçada, violando completamente o requisito de não transmiti-la diretamente e expondo o segredo a qualquer interceptador.

#### 5) A — KMS (Key Management Service).

✓ **Por que está certa:** O KMS (Key Management Service) é um serviço gerenciado de criptografia oferecido por provedores de nuvem (AWS KMS, Azure Key Vault, Google Cloud KMS) que centraliza o ciclo de vida completo de chaves criptográficas: geração, armazenamento seguro, rotação automática, políticas de acesso granular via IAM e auditoria de uso. No contexto do CompTIA Security+ (domínio 3.4 - 'Given a scenario, apply cybersecurity solutions to the cloud'), o KMS é a solução padrão para gerenciar chaves de criptografia em ambientes de nuvem, permitindo que dados em repouso (EBS, S3, RDS) e em trânsito sejam protegidos com chaves controladas pelo cliente ou pelo provedor. Ele atende exatamente ao requisito de 'criar, rotacionar e controlar acesso' a chaves, sendo a resposta correta.

#### ✗ **Por que as outras estão erradas:**

- **IAM:** O IAM (Identity and Access Management) é um serviço de gerenciamento de identidades e permissões que controla quem pode acessar quais recursos na nuvem, definindo usuários, grupos, roles e políticas. Embora o IAM seja usado para autorizar o acesso ao KMS, ele não gerencia chaves criptográficas em si — não cria, rotaciona ou armazena chaves. Portanto, é incorreto para o enunciado, que pede especificamente o serviço de gerenciamento de chaves.
- **CDN:** O CDN (Content Delivery Network) é uma rede distribuída de servidores de borda que armazena em cache conteúdo estático (imagens, vídeos, scripts) para reduzir latência e melhorar a entrega aos usuários. Ele não tem relação com gerenciamento de chaves criptográficas; sua função é otimização de desempenho e disponibilidade, não segurança de chaves. Logo, não atende ao requisito.
- **VPC:** O VPC (Virtual Private Cloud) é uma rede virtual isolada dentro da nuvem, onde o usuário define sub-redes, tabelas de roteamento, gateways e grupos de segurança. Trata-se de um serviço de infraestrutura de rede, não de gerenciamento de chaves. Embora possa hospedar instâncias que usam KMS, o VPC em si não cria, rotaciona ou controla chaves criptográficas. Portanto, é incorreto para a questão.

#### 6) D — Implementar a solução correspondente: AES = simétrico; RSA = assimétrico....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Public Key Infrastructure (PKI)): AES = simétrico; RSA = assimétrico.

#### ✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**7) C — Implementar a solução correspondente: Assimétrico: pública cifra, privada decifra (ou assina)....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Public Key Infrastructure (PKI)): Assimétrico: pública cifra, privada decifra (ou assina).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**8) C — Implementar a solução correspondente: PGP: combina a 2 (RSA pra trocar a chave + AES pro conteúdo)....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Public Key Infrastructure (PKI)): PGP: combina a 2 (RSA pra trocar a chave + AES pro conteúdo).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**9) D — Implementar a solução correspondente: 'requires a mathematical relationship between two cryptographic keys' = ass....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Public Key Infrastructure (PKI)): 'requires a mathematical relationship between two cryptographic keys' = assimétrica (PKI).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**10) B — Implementar a solução correspondente: AES vs RSA: não confunde — a prova gosta de citar algoritmos....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Public Key Infrastructure (PKI)): AES vs RSA: não confunde — a prova gosta de citar algoritmos.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.